



CENTRO UNIVERSITÁRIO DINÂMICA DAS CATARATAS

Missão: Formar profissionais capacitados, socialmente responsáveis e aptos a promoverem as transformações futuras para o mundo do trabalho.

Nome: Andrey Teodoro Alves de Lima

Professor: Miguel Diogenes Matrakas

Disciplina: Tópicos Especiais em Tecnologia de Informação I

Período: 7º

Capítulo 1

Questão 2:

IaaS (Infrastructure as a Service / Infraestrutura como Serviço):

- O que é gerenciado pelo cliente: O cliente é responsável por gerenciar o sistema operacional, os dados e as aplicações.
- O que é gerenciado pelo provedor: O provedor gerencia a infraestrutura física subjacente.
- Exemplo de serviço real: Amazon EC2, Microsoft Azure VMs ou Google Compute Engine.

PaaS (Platform as a Service / Plataforma como Serviço):

- O que é gerenciado pelo cliente: O foco total do cliente é no desenvolvimento e gerenciamento da aplicação.
- O que é gerenciado pelo provedor: O provedor gerencia toda a infraestrutura subjacente, como o hardware, o sistema operacional, etc.
- Exemplo de serviço real: Google App Engine ou AWS Elastic Beanstalk.

SaaS (Software as a Service / Software como Serviço):

- O que é gerenciado pelo cliente: Nenhum controle sobre a infraestrutura ou plataforma; o cliente apenas utiliza o software.
- O que é gerenciado pelo provedor: O provedor de nuvem gerencia absolutamente tudo.
- Exemplo de serviço real: Gmail, Office 365 ou Dropbox.

Questão 3:

Nuvem Pública: Pertence e é operada por um provedor de serviços terceirizado, com toda a infraestrutura física sendo compartilhada entre múltiplos clientes. Situação indicada: Indicada para empresas que precisam de rápida implantação, alta escalabilidade e menor investimento inicial, sem a necessidade de manter infraestrutura própria.

Nuvem Privada: Consiste em recursos de computação que são utilizados exclusivamente por uma única empresa ou organização, podendo estar localizados fisicamente no data center local da própria instituição. Situação indicada: Indicada para organizações que exigem maior controle, segurança, conformidade regulatória e proteção de dados sensíveis, como bancos, hospitais e órgãos governamentais.

Nuvem Híbrida: Combina os ambientes de nuvens públicas e privadas, unindo-os por tecnologias que permitem o compartilhamento seguro de dados e aplicações entre eles. Situação indicada: Indicada para empresas que precisam combinar segurança e controle da nuvem privada com a escalabilidade e flexibilidade da nuvem pública, mantendo dados sensíveis em ambiente privado e outras aplicações na nuvem pública.

Questão 4:

A arquitetura serverless é um conceito que permite executar código sem a necessidade de provisionar ou gerenciar servidores diretamente. O funcionamento baseia-se na execução do código em resposta a eventos específicos (como requisições HTTP ou uploads de arquivos), cabendo ao provedor alocar dinamicamente e gerenciar a infraestrutura. Principais vantagens: Foco total no desenvolvimento do código, escalabilidade automática e granular, e cobrança estrita pelo tempo de computação consumido. Exemplos de serviços: AWS Lambda e Azure Functions.

Capítulo 2

Questão 2:

On-premises: Os recursos ficam instalados fisicamente no ambiente do próprio órgão ou empresa. Vantagens/Desvantagens: Oferece controle total das máquinas, mas exige um CapEx substancialmente maior e possui escala mais lenta.

Colocation: Os equipamentos pertencem ao cliente, mas são instalados dentro de um data center terceirizado, alugando-se o espaço físico, energia elétrica de precisão e links de conectividade. Vantagens/Desvantagens: Permite uma operação mista, utilizando hardware proprietário, mas delegando a sustentação predial crítica (energia/climatização) ao data center parceiro.

Nuvem: Os recursos computacionais são virtuais e fornecidos sob demanda por um provedor especializado. Vantagens/Desvantagens: Financiado puramente via despesas operacionais (OpEx/pay-as-you-go), permite uma escala extremamente ágil e conta com serviços gerenciados de fábrica, contudo reduz o controle direto da infraestrutura física subjacente.

Questão 7:

TCO (Total Cost of Ownership): Significa o Custo Total de Propriedade de uma solução de tecnologia. Deve obrigatoriamente incluir o preço de aquisição inicial, despesas com licenciamento de software, custos de manutenção contínua, gastos energéticos e refrigeração, além do custo com o pessoal especializado (equipe) para gerenciar o ambiente.

A avaliação econômica precisa abranger os custos recorrentes operacionais de longo prazo para evitar impactos

imprevistos no orçamento da TI ao longo do ciclo de vida útil da solução.

Capítulo 3

Questão 2:

SPOF (Single Point of Failure / Ponto Único de Falha): Representa qualquer componente ou link isolado de um sistema que, caso venha a falhar ou sofrer uma pane, provocará a interrupção total dos serviços de TI associados devido à ausência de redundância. É indesejado porque afeta diretamente o uptime e degrada a disponibilidade do data center.

Exemplos de SPOF: Energia: Operar com apenas uma concessionária de energia ou uma única UPS ativa (configuração N). Rede: Utilizar um switch de core ou roteador único de borda na topologia. Armazenamento: Possuir uma única controladora de storage ou discos sem arranjos de proteção contra quebras físicas.

Questão 3:

N: Representa a capacidade exata exigida para alimentar a carga atual do data center, sem qualquer elemento extra de reserva ou redundância (tolerância zero a falhas).

N+1: Adiciona um componente de reserva ativa (reserva quente) ao sistema; caso um módulo falhe, o elemento sobressalente assume a operação sem causar quedas (permite manutenção concorrente).

2N: Fornece a capacidade totalmente duplicada do sistema através de dois caminhos de alimentação independentes e isolados para cada componente crítico.

Modelo que oferece maior disponibilidade: O modelo 2N é o que entrega a máxima disponibilidade, pois é categorizado como totalmente tolerante a falhas (fault-tolerant), suportando a perda completa de um caminho inteiro de energia sem desabastecer os equipamentos de TI, com um downtime anual projetado de apenas 36 minutos no padrão Tier IV.

Questão 6:

- Alta Disponibilidade (HA) tem como objetivo manter os serviços funcionando mesmo diante de falhas, utilizando redundância para minimizar ou evitar interrupções.
- Recuperação de Desastres (DR) tem como objetivo restaurar os serviços e dados após eventos graves, como desastres naturais, falhas catastróficas ou ataques.

Como se complementam: a HA reduz ou evita indisponibilidades causadas por falhas comuns, enquanto o DR garante a recuperação do ambiente quando ocorre um desastre que supera os mecanismos de alta disponibilidade.

Questão 12:

PUE (Power Usage Effectiveness) é uma métrica que mede a eficiência energética de um data center, relacionando a energia total consumida com a energia utilizada pelos equipamentos de TI. $PUE = 1,0$ representa eficiência ideal, onde toda a energia consumida é usada apenas pelos equipamentos de TI, sem desperdícios com refrigeração, iluminação ou outros sistemas.

Os data centers modernos buscam valores entre 1,1 e 1,3 porque isso indica alta eficiência energética, reduzindo custos operacionais e o impacto ambiental.

Questão 18:

Nível Tier Mínimo: Tier IV.

Justificativa: De acordo com os padrões, um ambiente Tier III tolera até 1,6 hora (96 minutos) de parada anual, o que violaria o limite de 52 minutos exigido pelo SLA de 99,99%. Somente o Tier IV, com sua disponibilidade típica de 99,995% (limite de 26 minutos de parada anual), é capaz de assegurar essa métrica com segurança técnica. Para alcançar isso, ele exige uma infraestrutura tolerante a falhas (2N) com dois caminhos de energia e climatização simultaneamente ativos, garantindo que qualquer falha em uma linha seja instantaneamente absorvida pela outra.

Duas Medidas Operacionais Complementares:

- 1- Criação e atualização de runbooks detalhados com procedimentos claros de operação e failover.
- 2- Realização regular de testes periódicos de failover e simulações de desastre para garantir a prontidão da equipe e dos sistemas.

Capítulo 4

Questão 2:

Block Storage (Bloco): O dado é tratado de forma bruta no nível mais baixo (raw volume), e o sistema de arquivos é criado e gerenciado inteiramente pelo sistema operacional do cliente. O acesso se dá por protocolos de rede SAN como iSCSI ou Fibre Channel. Caso de uso típico: Hospedagem de Bancos de Dados Relacionais de alto desempenho ou discos para Máquinas Virtuais.

File Storage (Arquivo): O próprio dispositivo de armazenamento (NAS) gerencia a estrutura hierárquica do

sistema de arquivos (pastas e arquivos) e a compartilha na rede corporativa através de protocolos de rede padrão. Caso de uso típico: Servidores de arquivos compartilhados para usuários finais corporativos via protocolos SMB/CIFS ou NFS.

Object Storage (Objeto): Os dados são armazenados como unidades isoladas (objetos) dentro de um repositório plano (sem hierarquia de pastas), onde cada objeto recebe um identificador único e metadados customizáveis. O acesso ocorre estritamente via APIs HTTP/REST. Caso de uso típico: Repositórios massivos e escaláveis em nuvem para armazenamento de mídias estruturadas/não estruturadas, backups globais e arquivos mortos.

Questão 3:

Backup: É uma cópia independente e completa dos dados de produção guardada em um repositório ou mídia externa fisicamente isolada, visando a recuperação a longo prazo.

Snapshot: É um registro instantâneo e pontual (ponto no tempo) do estado dos ponteiros de um volume de disco. Ele ocorre quase em tempo real e serve para retornos rápidos a estados anteriores.

Replicação: É o processo de copiar continuamente (de forma síncrona ou assíncrona) os dados de um storage para outro site geograficamente distribuído para fins de alta disponibilidade ou recuperação de desastres.

O Snapshot substitui o Backup? Não. O snapshot reside na mesma estrutura física e controladoras do storage original. Caso ocorra uma falha catastrófica no hardware ou um ataque destrutivo de ransomware no storage corporativo, todos os

snapshots guardados nele serão perdidos junto com a produção. Ele viola a regra de isolamento da cópia.

Questão 5:

É a prática estratégica de classificar os dados corporativos conforme a sua frequência de acesso e distribuí-los automaticamente em diferentes camadas (tiers) de mídias de armazenamento com características distintas de custo e velocidade. Os dados mais acessados ("quentes") vão para o Tier superior de alto desempenho (NVMe/SSDs), enquanto os dados de arquivo/históricos ("frios") vão para camadas mais baratas e lentas (HDDs/Fitas). Juntos, o cache (que atua como um buffer ultrarrápido em RAM ou NVMe para absorver as requisições imediatas de leitura/escrita) e o auto-tiering evitam o superdimensionamento da infraestrutura. Eles garantem desempenho de ponta para o que é crítico no negócio sem a necessidade financeira proibitiva de armazenar 100% dos dados corporativos nas mídias de armazenamento mais caras do mercado.

Questão 11:

A Regra 3-2-1 determina o seguinte esquema básico de proteção:

3 cópias distintas de todos os dados corporativos críticos (sendo 1 de produção ativa e mais 2 backups adicionais).

2 mídias ou tecnologias de armazenamento totalmente diferentes para salvar as cópias (por exemplo, salvar em discos rígidos locais e fitas LTO, ou em storage local e nuvem pública).

1 cópia mantida estritamente offsite, ou seja, em um local geográfico ou ambiente isolado totalmente diferente da sua sede principal.

Problema dos Snapshots Isolados: Manter apenas snapshots não atende a essa estratégia regulatória porque eles residem dentro do próprio hardware de origem. Se o storage sofrer uma quebra nas placas de circuito, desastre físico ou for atacado por um ransomware com privilégios administrativos elevados, os dados originais e os snapshots serão apagados ou criptografados ao mesmo tempo, gerando perda total.

Questão 14:

Critério	DAS (<i>Direct Attached Storage</i>)	NAS (<i>Network Attached Storage</i>)	SAN (<i>Storage Area Network</i>)
Protocolo de Acesso	Conexão elétrica direta via barramento local SAS, SATA ou PCIe.	Protocolos de compartilhamento de arquivos via rede IP (NFS, SMB/CIFS).	Protocolos de bloco de baixo nível via iSCSI ou Fibre Channel (FC).
Caso de Uso Típico	Servidores standalone isolados, nós locais de infraestrutura hiperconvergente (HCI).	Compartilhamento corporativo de pastas de trabalho e repositórios comuns de usuários.	Storages centralizados de alta performance para Bancos de Dados críticos e Clusters de Virtualização.
Complexidade	Baixa. Não depende de switches ou projetos complexos de redes dedicadas.	Média. Depende apenas de configurações padrão de rede local Ethernet TCP/IP.	Alta. Exige switches dedicados, placas controladoras HBA e configuração avançada de Zoneamento.

Questão 15:

- Backup Incremental: Copia apenas os arquivos e blocos de dados que foram modificados ou criados desde a realização do último backup executado (seja ele um backup Full ou outro incremental).
- Backup Diferencial: Copia de forma cumulativa todos os dados modificados estritamente desde a última execução do backup Full principal (com o seu tamanho aumentando ao longo dos ciclos semanais).
- Restore Mais Rápido (Menor RTO): O Backup Diferencial oferece uma recuperação mais veloz. Para reconstruir o ambiente, o operador precisa restaurar apenas dois arquivos: o último Backup Full e o arquivo Diferencial mais recente daquela data. O incremental exige aplicar o Full e toda a cadeia sequencial de incrementais diários, o que atrasa o processo.
- Menos Espaço Usado: O Backup Incremental é muito mais econômico em armazenamento, pois nunca duplica blocos de dados salvos nos dias anteriores da mesma semana.

Questão 18:

A) Arquitetura das Camadas (Tiers): Tier 0/1 (Dados Quentes - 20 TB): Alocação em SSDs NVMe (PCIe) para entregar o máximo de IOPS e latência ultra-baixa para processamento transacional ativo. Tier 2 (Dados Mornos - 60 TB): Alocação em SSDs ou HDDs SAS/SATA corporativos, equilibrando boa capacidade operacional com custos intermediários. Tier 3 (Dados Frios - 20 TB): Alocação em HDDs mecânicos de alta capacidade ou Object Storage, focados estritamente em custo por Terabyte reduzido.

B) Critérios de Movimentação Automática: Configuração de políticas através de softwares de auto-tiering. O sistema deve monitorar em tempo real os blocos de dados: blocos sem leituras por mais de 30 dias devem ser rebaixados (demoted) automaticamente para a camada morna ou fria; se um bloco frio for requisitado por uma aplicação, o software deve promovê-lo instantaneamente (promoted) para a camada NVMe de alto desempenho.

C) Vantagem Econômica: Evita o desperdício financeiro crítico. Armazenar os 100 TB inteiros em NVMe geraria um custo altíssimo desnecessário, já que 80% daqueles dados não exigem latência de microssegundos. Usando mídias econômicas (HDDs/SAS) nos 80 TB remanescentes, reduz-se drasticamente o Custo Total de Propriedade (TCO) de armazenamento da empresa mantendo a percepção de alta performance do sistema.

Capítulo 6

Questão 1:

- Ransomware: É um malware que invade o ambiente (geralmente por e-mails de phishing ou brechas em portas expostas), executa a criptografia forçada de todos os volumes de dados locais e exige pagamentos de resgate. Ele pode paralisar a operação inteira da empresa.
- Phishing / Engenharia Social: É a manipulação psicológica aplicada contra colaboradores internos através de e-mails, links ou mensagens falsas que se passam por comunicações legítimas. O atacante a explora para roubar credenciais de acesso válidas à rede corporativa.
- Exploração de Vulnerabilidades: É o ataque focado em sistemas operacionais ou softwares desatualizados que

possuem falhas de código públicas conhecidas (CVEs). O atacante a explora para obter execução remota de código ou privilégios indevidos antes que a TI aplique os patches de correção.

- Ataques de DDoS (Negação de Serviço Distribuída): Consiste em coordenar uma avalanche massiva de conexões falsas direcionadas contra os servidores públicos ou links de internet da empresa. Explora a limitação física de hardware e banda para esgotar os recursos e derrubar os serviços legítimos para os clientes.

Questão 4:

O Ciclo Contínuo de Gestão é composto por 5 etapas sequenciais:

- 1- Inventário: Mapear e cadastrar todos os ativos e softwares do ambiente.
- 2- Varredura (Scan): Executar ferramentas automáticas para descobrir falhas ativas nos sistemas.
- 3- Priorização: Classificar e ordenar as brechas encontradas com base no risco real.
- 4- Correção: Aplicar os patches de software, atualizações ou contramedidas técnicas.
- 5- Validação: Refazer os testes para homologar e garantir que a falha foi sanada.

Critérios de Priorização: Não se deve avaliar apenas a nota bruta do CVSS. Deve-se cruzar o CVSS (gravidade teórica) com a exposição do sistema e a existência de exploits públicos ativos na internet. Uma vulnerabilidade crítica com código de ataque público em um servidor web exposto à internet recebe prioridade máxima absoluta sobre uma falha interna isolada.

Questão 5:

Etapas do Ciclo NIST (SP 800-61):

- Preparação: Estruturar e treinar o time de resposta (CSIRT) e criar os runbooks de reação.
- Identificação: Detectar anomalias, analisar os logs e confirmar se o evento é uma invasão real.

Contenção: Isolar e confinar os sistemas afetados na rede para estancar a propagação do ataque.

- Erradicação: Remover as causas raiz, eliminando malwares, limpando backdoors e fechando brechas.
- Recuperação: Restaurar com segurança os sistemas a partir de backups limpos e homologar o retorno.
- Lições Aprendidas: Conduzir a reunião de post-mortem com os envolvidos.

O que deve ser documentado ao final: Deve ser gerado um relatório de post-mortem registrando minuciosamente a cronologia detalhada dos fatos, a causa raiz explorada, o impacto financeiro/operacional real, as ações tomadas pela equipe e a lista obrigatória de melhorias na infraestrutura para evitar que o evento se repita.

Questão 6:

O RBAC é o modelo de controle de acessos onde os direitos e privilégios administrativos dentro do sistema são vinculados estritamente a funções ou papéis organizacionais (perfis), e não às contas individuais de pessoas físicas. Impede a ocorrência de privilégios excessivos causados pelo acúmulo de acessos (conhecido como privilege creep). Quando um analista muda de cargo ou setor na empresa, a TI simplesmente altera o seu papel

no sistema centralizado; automaticamente, todas as permissões do cargo antigo são revogadas e apenas as estritamente cruciais para a nova função são ativadas, mantendo o controle sob rígida governança.

Questão 15:

Diferença Funcional: O IDS atua de forma puramente reativa e passiva; ele monitora as cópias dos pacotes de dados trafegados e dispara alertas em tempo real para a equipe de segurança caso identifique um padrão malicioso, sem interferir no fluxo. O IPS atua de forma proativa e ativa; ele analisa o tráfego em tempo real e possui a capacidade técnica de interceptar, descartar pacotes e bloquear conexões maliciosas de forma automatizada.

Posicionamento na Topologia: O IDS é instalado fora de banda (out-of-band), conectado a uma porta de espelhamento (SPAN) do switch de rede. O IPS é instalado em linha (inline), ou seja, atravessando fisicamente o fluxo principal de dados (geralmente posicionado entre o roteador de borda e o switch central ou integrado ao NGFW) para que todo o tráfego passe obrigatoriamente por ele.

Questão 17:

- Criptografia Simétrica: Utiliza uma única chave secreta compartilhada tanto para cifrar quanto para decifrar a informação. É extremamente veloz no processamento de grandes massas de dados, mas possui um desafio complexo na distribuição segura dessa chave secreta inicial.
- Criptografia Assimétrica: Utiliza um par de chaves matemáticas relacionadas entre si: uma Chave Pública (aberta ao mundo, usada para cifrar os dados) e uma Chave

Privada (sob posse exclusiva do dono, usada para decifrar). Resolve o problema de troca de chaves na internet, porém exige alto custo computacional de processamento.

Equilíbrio no TLS (HTTPS): O protocolo TLS unifica as duas abordagens de forma simbiótica:

- Fase Inicial (Handshake): Utiliza a criptografia assimétrica (mais lenta, porém segura) apenas para que o navegador valide a identidade do servidor corporativo e combine a criação de uma chave temporária de sessão.
- Fase de Transmissão: Uma vez combinada essa chave de sessão efêmera, o TLS desativa o processamento assimétrico e passa a criptografar 100% do tráfego volumoso de dados via criptografia simétrica (AES-256), assegurando máxima segurança sem degradar o desempenho e a velocidade da navegação.

Questão 20:

Modelo Zero Trust vs Perímetro: O modelo clássico perimetral (*castle-and-moat*) assume que qualquer usuário ou dispositivo localizado geograficamente dentro dos cabos da rede interna corporativa é confiável por padrão, focando as defesas apenas nas bordas da internet. O Zero Trust inverte essa lógica sob a premissa de "Nunca confiar, sempre verificar". Não importa a localização física: todo e qualquer acesso deve ser autenticado, autorizado e criptografado continuamente.

Pilares Tecnológicos Necessários: Para viabilizar esse ecossistema complexo de trabalho híbrido, são fundamentais o uso de soluções de ZTNA (Acesso de Rede Zero Trust) para granularidade por aplicação, ferramentas robustas de gestão de identidades com MFA e RBAC centralizados, validações contínuas

de postura de conformidade dos endpoints via EDR/MDM e centralização de visibilidade através de um SIEM para detecção de anomalias.

Dois Riscos ou Limitações:

1. *Complexidade de Implementação e Gestão:* Exige um esforço hercúleo de mapeamento de todos os workloads e dados corporativos, o que pode sobrecarregar o time de TI e gerar fricção na experiência diária do usuário final se as regras forem excessivamente engessadas.
2. *Custo Financeiro Elevado:* Demanda altos investimentos recorrentes de licenciamento (OpEx) para substituir as soluções legadas por plataformas modernas integradas de segurança.